

Lab - Investigating OWASP

Objectives

Part 1: OWASP Top 10

Part 2: OWASP Community Pages

Background / Scenario

[Open Web Application Security Project \(OWASP\)](https://owasp.org/) is a non-profit organization that is dedicated to web application security. OWASP publishes a list of the Top 10 most critical web security concerns facing organizations about every three years. The objective of this report is to raise awareness regarding web application security and to help organizations incorporate this information into their process to minimize and mitigate security risks.

OWASP also accepts community contributions for security related content. The [OWASP Community Pages](https://owasp.org/Community/) provides list of attacks and vulnerabilities reported by the communities.

In this lab, you will explore the OWASP Top 10 from 2021 and a few of the attacks and vulnerabilities reported by community contributors.

Required Resources

= Internet access

Instructions

Part 1: OWASP Top 10

- Navigate to the OWASP Top 10 (<https://owasp.org/Top10>).
- At the time of this writing, the draft of latest list of Top 10 was published in 2021.

Review the Top 10 categories. Pick 3 categories out of the Top 10. In the table below, list your chosen categories. Then briefly describe the category and some of the ways to prevent attacks in the category.

Top 10 Category	Description	Prevention
Security Misconfiguration	Security misconfiguration is when a system, application, or cloud service is set up incorrectly from a security perspective, creating vulnerabilities.	An automated process to verify the effectiveness of the configurations and settings in all environments.

Injection	An injection vulnerability is an application flaw that allows untrusted user input to be sent to an interpreter (e.g. a browser, database, the command line) and causes the interpreter to execute parts of that input as commands.	Use positive server-side input validation. This is not a complete defense as many applications require special characters, such as text areas or APIs for mobile applications.
Security Logging and Alerting Failures	Without logging and monitoring, attacks and breaches cannot be detected, and without alerting it is very difficult to respond quickly and effectively during a security incident. Insufficient logging, continuous monitoring, detection, and alerting to initiate active responses occurs any time	Ensure all login, access control, and server-side input validation failures can be logged with sufficient user context to identify suspicious or malicious accounts and held for enough time to allow delayed forensic analysis.

Part 2: OWASP Community Pages

The OWASP Community Pages allows security-related contributions from the community. In this part, you will review the Vulnerabilities pages to investigate the attack techniques reported by the contributors.

- a. Navigate to the OWASP Community Page for Vulnerabilities.
(<https://owasp.org/www-community/vulnerabilities/>).

OWASP defines a vulnerability as flaw in the application that a threat actor can exploit.

Review the List of Vulnerabilities and pick 3. In the table below, list your chosen vulnerabilities. Briefly describe the vulnerability and some of the ways to prevent exploitation.

Vulnerabilities	Description	Prevention
Empty String Password	Using an empty string as a password is insecure. It is never appropriate to use an empty string as a password. It is too easy to guess. An empty string password makes the authentication as weak as the user names, which are normally public or guessable. This makes a brute-force attack against the login interface much easier.	Use strong password, Change often
Injection problem	Injection problems span a wide range of instantiations. The basic form of this flaw involves the injection of control-plane data into the data-plane in order to alter the control flow of the process.	The process may be altered by sending code in through legitimate data channels, using no other mechanism. While buffer overflows, and many other flaws, involve the use of some further issue to gain execution, injection problems need only for the data to be parsed.
Using freed memory	Referencing memory after it has been freed can cause a program to crash. The use of heap allocated memory after it has been freed or deleted leads to undefined system behavior and, in many cases, to a write-what-where condition. Use after free errors occur when a program continues to use a pointer after it has been freed. Like double free errors and memory leaks, use after free errors have two common and sometimes overlapping causes	Implementation: Ensuring that all pointers are set to NULL once the memory they point to has been freed can be an effective strategy. The utilization of multiple or complex data structures may lower the usefulness of this strategy.

- b. Navigate to the OWASP Community Page for Attacks. (<https://owasp.org/www-community/attacks>).

According to OWASP, an attack is a technique used to exploit application vulnerabilities.

Review the **List of Attacks** and pick 3. In the table below, list your chosen attacks. Then briefly describe the attack and some of the ways to prevent it.

Attacks	Description	Prevention
Binary Planting	Binary planting is a general term for an attack where the attacker places (i.e., plants) a binary file containing malicious code to a local or remote file system in order for a vulnerable application to load and execute it.	Secure coding, System hardening, User awareness
Full Path Disclosure	Full Path Disclosure (FPD) vulnerabilities enable the attacker to see the path to the webroot/file. e.g.: /home/omg/htdocs/file/. Certain vulnerabilities, such as using the load_file() (within a SQL Injection) query to view the page source, require the attacker to have the full path to the file they wish to view.	Configure proper error handling and logging, Sanitize user input, Server and environment hardening
Spyware	Spyware is a program that captures statistical information from a user's computer and sends it over the internet without user acceptance. This information is usually obtained from cookies and the web browser's history. Spyware can also install other software, display advertisements, or redirect the web browser activity. Spyware differs from a virus, worm, and adware in various ways. Spyware does not self-replicate and distribute itself like viruses and worms, and does not necessarily display advertisements like adware.	Software and security tools, Safe browsing and downloading habits, Device and account security